
Social Engineering

TELMO SAUCE

DETI - Departamento de Electrónica, Telecomunicações e Informática, Universidade de Aveiro

Email: telmobelasauce@ua.pt

As technology becomes essential not only to our daily lives but also to organizational operations, the growing reliance on digital systems heightens the need for robust security measures to prevent failures and counter malicious actors. Social engineering attacks have shown a significant evolution and are becoming a significant threat to organizational security, targeting the weakest link, the human. These attacks can bypass security measures and evade traditional defenses, making them particularly challenging to mitigate. To address these threats, institutions must not only enhance technical defenses but also invest in comprehensive staff training, prevention strategies, and ongoing readiness assessments. However, keeping these programs updated to the ever-evolving social engineering landscape, along with conducting regular tests such as physical social engineering exercises or phishing campaigns, can be costly, time-consuming and disruptive to the normal working flow of the company. This article aims to analyze the current state of social engineering threats, explore common attack techniques, and assess the measures organizations use to combat these risks.

Keywords: Cybersecurity, Social Engineering, Social engineering attacks, Social engineering thecquines, Security Awareness, Threat Mitigation

Received 00 January 2009; revised 00 Month 2009

1. INTRODUCTION

As the world becomes increasingly digital, technology plays a crucial role in our daily lives, shaping how we work, communicate, and manage information. By digitalizing their operations, organizations leverage computers to optimize workflows and safeguard essential data. This transformation has made institutions and individuals more dependent on digital infrastructures. A failure in these systems can have devastating consequences, reinforcing the necessity of their reliability and protection against malicious threats.

In addition, as technology evolves, so do the threats against them, pushing traditional defense mechanisms to their limits, requiring institutions to adopt comprehensive and adaptive strategies to safeguard their assets against a wider range of risks.

One concerning trend in cybersecurity is the rise of social engineering attacks, which exploit human psychology rather than relying solely on technical vulnerabilities. For instance, a report by Positive Technologies indicated that social engineering accounted for 43% of incidents recorded in the first half of 2023, increasing to 57% in the first half of 2024 ¹.

Hackers can employ various techniques to deceive their victims into revealing sensitive information or to

gain unauthorized access. Digital social engineering tactics, such as phishing, which are fraudulent emails designed to steal personal information, are among the most prevalent strategies. Besides digital methods, physical social engineering attacks are becoming a significant threat. These bypass conventional cybersecurity measures and often target directly the weakest link in the security chain, the human. Cybercriminals can combine social engineering tactics with technical methods to create hybrid attacks, which are challenging to defend against. These allow hackers to bypass initial security measures and infiltrate organizations, leveraging social engineering to obtain the initial access, followed by technical techniques to deepen infiltration or to exfiltrate data. Once inside, this hybrid attacks become harder to detect and mitigate, as they appear to originate from within the system itself. Although detection technologies have improved, they are far from "bulletproof" and often fail to keep pace with evolving attack methods. Hackers are constantly refining their tactics, which makes detection and mitigation more challenging for automated systems. For institutions, this means that securing their digital systems is no longer enough. They must train their staff to recognize these threats, develop robust prevention processes, and continuously test their capacity to respond to these rapidly evolving attack vectors.

¹<https://global.ptsecurity.com/analytics/cyberthreats-in-the-public-sector>

2. SOCIAL ENGINEERING

Social engineering refers to all techniques aimed at convincing a individual to reveal specific information or perform a specific action for illegitimate reasons. It takes advantage of human limitations and their flawed nature, increasing its difficulty to counter attacks through standard hardware or software-based solutions [1, 2]. While awareness training can help reduce their probability, a complete prevention is challenging, as people remain susceptible to manipulation, misplacing their trust [2]. The number of social engineering attacks has significantly increased in recent years, reaching 57% of reported incidents in 2024, representing an 11% increase compared to 2023 ². In 2023, the Computer Emergency Response Team for Portugal (CERT.PT) reported that phishing/smishing incidents were the most frequently recorded, accounting for 35% of all cases, while other social engineering incidents covered 10%. Among the subtypes of social engineering incidents, vishing was the most prevalent, representing 35% of the total, followed by CEO fraud with 31% ³.

3. SOCIAL ENGINEERING STAGES

Social engineering attacks come in many forms, but they follow a distinct pattern which unfolds across several stages [2]. A widely recognized model illustrating these phases is **the social engineering attack cycle** by Kevin Mitnick [3]. This model has four stages: **Research**, **Developing Rapport and Trust**, **Exploiting Trust**, and **Utilising Information**.

On the **Research** stage, the attacker seeks to retrieve data about the target. The goal is to collect as much information as possible, which strengthens the attack vector for the following stages, as the quality of the obtained data increases the likelihood of establishing a strong, trusting relationship with the individual [4].

The next stage is the **Developing Rapport and Trust** of the victim, during which the attacker tries to create a relationship with the target. This stage is essential as the probability of sharing the requested information to a trusted individual is exponentially higher [3]. This can be accomplished by misrepresenting an identity, citing trustworthy individuals associated with the entity, showing a need for assistance, or faking an authoritative role [4].

Next comes the **Exploiting Trust** phase, where the trusting relationship formed in the previous phase between the individual and the malicious actor is abused. The attacker influences the victim emotionally to provide sensitive data or to make security mistakes [2, 4]. To accomplish this, hackers can request information,

ask the target to perform an action, or manipulate the user into seeking help [3].

Finally, the last phase, **Utilising Information**, is where the attacker attempts to exit without leaving any proofs [2]. This phase uses the previous data to reach the attack's goal or to advance to further steps which may be required to accomplish it [4].

The authors of the **Social Engineering attack framework** [4] propose several modifications to the Kevin Mitnick model. They introduce an initial phase called **Attack Formulation**, during which the social engineer establishes a clear goal for the attack and identifies a suitable target. Following the Research stage, the authors add a **Preparation** phase that focuses on consolidating the gathered data, crafting the attack vectors, and planning the attack. Next, the authors discuss if the **Utilising Information** stage should be included in the social engineering attack, as the objective has already been met, and utilizing that data is no longer part of the attack itself. They replace this phase with **Debriefing** stage, at which the attacker should make the target return to a normal emotional state, which was constructed during the **Exploitation Phase**. This step is essential to ensure the target does not reflect on what occurred, similarly to the **Impact** phase at the cyberattack lifecycle in which the hacker tries to cover its actions. The final step of the **Debriefing** phase is **Transition**, during which the social engineer determines if the goal was achieved, or if it should return to the **Research** phase.

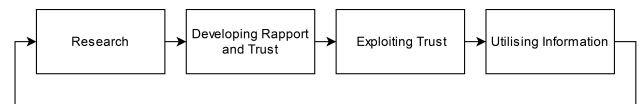


FIGURE 1. Social engineering attack cycle [4]

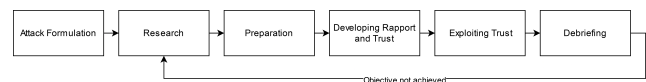


FIGURE 2. Social engineering attack framework

4. CLASSIFICATION

Social engineering attacks can be categorized in various ways depending on the perspective of the social engineer.

4.1. Entity Based Social Engineering

One form to categorize these attacks is by the type of entity executing the attack. They can be divided into two categories: human-based or software-based. In human-based attacks, the attacker engages in direct communication, typically in person or through methods such as phone calls or impersonation, to extract the

²<https://global.ptsecurity.com/analytics/cyberthreats-in-the-public-sector>

³<https://www.cncs.gov.pt/docs/rel-riscosconflitos2024-obcibercncs.pdf>

desired information [2]. This attack relies heavily on the attacker's ability to manipulate the target through nonverbal cues, such as tone, appearance, and body language, making it challenging to scale or automate [2, 5]. While the scope may seem limited compared to software-based attacks, human-based attacks can adapt dynamically to different situations. Attackers can respond to subtle behavioral signals, such as hesitation or discomfort, and adjust their strategies in real time to build trust and reduce suspicion. Software-based attacks are carried out with devices or systems to automate the process, making it possible to target many victims simultaneously with minimal effort. These techniques allow attacks to reach thousands of targets within seconds, dramatically increasing the likelihood of success, as deceiving only one victim can produce valuable results [2]. Such attacks are highly efficient because they are automated and scalable, allowing attackers to achieve their goals without needing direct, real-time engagement.

4.2. Approach Based Social Engineering

Attacks can also be classified by approach and divided into three categories: physical-based, social-based, and technical-based. Physical-based attacks involve the attacker performing physical actions to retrieve sensitive data from the target. Often used techniques include dumpster diving, where attackers search through dumpsters looking for valuable documents or information, such as passwords, and tailgating, in which the social engineer follows an authorized individual into a restricted area without proper identification or clearance [6, 2]. Such attacks can be advantageous because they evade digital security systems entirely by targeting weak points in physical security. Additionally, through physical access, attackers can install malicious devices, like rogue routers, which blend into the local network and can remain undetected for extended periods. Technical-based approaches are mainly carried out over the internet, with hackers often using Open-source intelligence (OSINT) to gather information from the target's social media profiles and other public online resources [6]. One key advantage of this approach is that it is usually free, and the victim remains unaware of the malicious actor's actions, allowing them to gather valuable data without raising suspicion. Social-based attacks rely on creating relationships with the victim through interpersonal skills and psychological strategies to achieve this goal [2]. Unlike technical-based or physical-based attacks, which may use tools or physical access, social-based attacks center around human emotions, such as greed and curiosity. These emotions are frequently abused in tactics like phishing and baiting, where attackers create scenarios that deceive the target into sharing sensitive information or performing malicious actions against the organization.

4.3. Communication Based Social Engineering

The final classification method focuses on how the social engineer communicates with the victim, divided into two categories: direct and indirect communication. Direct communication refers to attacks where the victim interacts with the social engineer through physical presence, eye contact, or voice. Techniques which utilize this type of communication are shoulder surfing, phone-based social engineering, and impersonation [2]. Direct communication can be further divided into bidirectional and unidirectional communication. Bidirectional communication occurs when both parties participate in the conversation. For instance, the attacker may impersonate an IT support employee and try to obtain credentials. In unidirectional communication, the hacker initiates the interaction while the victim passively receives the message without responding, for example, a voicemail without requiring feedback. Finally, indirect communication occurs when there is no communication between the attacker and the victim. Instead, they use third-party methods to deceive their target, such as phishing emails or infected flash drives left strategically to lure victims into making insecure actions [4].

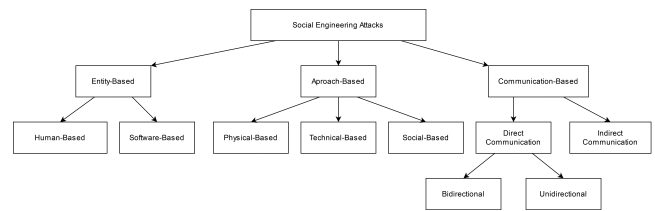


FIGURE 3. Social Engineering Classification Tree

5. TECHNIQUES AND CHANNELS

Social engineers must carefully select their channels and techniques by considering factors such as the attack's objectives, the stage of the interaction, and the information already gathered about the target. By understanding the strengths and weaknesses of each channel, social engineers can enhance their chances of achieving a successful outcome.

In the context of social engineering, a channel refers to the medium or method used by the attacker to manipulate or deceive the target. Different channels can facilitate different outcomes, some are better suited for gathering sensitive data, while others may be more effective for delivering malware or exploiting the target's trust. Attacks can be carried out through the following channels: email, websites, social media, cloud services, Instant Messaging Applications (IMA), Short Message Service (SMS), telephone/Voice over Internet Protocol (VoIP), and physical means.

The following table 1 provides an overview of the potential channels through which a malicious actor can

Technique	Email	Website	Social Media	Cloud Services	IMA	SMS	Telephone VoIP	Physical
Dumpster Diving	-	-	-	-	-	-	-	X
Shoulder Surfing	-	-	-	-	-	-	-	X
Tailgating and Piggybacking	-	-	-	-	-	-	-	X
KeyStroke Injection	-	-	-	-	-	-	-	X
Keylogger	X	-	-	-	-	-	-	X
Rogue Router	-	-	-	-	-	-	-	X
Deauthenticator	-	-	-	-	-	-	-	X
Phishing	X	X	X	X	-	-	-	-
Spear Phishing	X	X	X	-	-	-	-	-
Whaling	X	-	X	-	-	-	-	-
Vishing	-	-	-	-	-	-	X	-
Smishing	-	-	-	-	X	X	-	-
Search Engine Phishing	-	X	-	-	-	-	-	-
Watering Hole Attack	-	X	-	-	-	-	-	-
Fake Software	X	X	X	X	X	-	-	-
Pop-Up Windows	X	X	-	X	-	-	-	-
DNS Spoofing	-	X	-	-	-	-	-	-
Impersonation	X	-	X	-	X	X	X	X
Pretexting	X	-	X	-	X	X	X	-
Quid Pro Quo	X	X	X	-	X	X	X	-
Reverse Social Engineering	X	X	-	-	X	X	X	-
Baiting	-	-	-	-	-	-	-	X

TABLE 1. Mapping of Attack Techniques to Communication Channels [6, 5]

exploit a victim. Each technique outlined in it will be described in greater detail in a subsequent section. The techniques are structured according to the approach-based classification discussed in 4.2.

5.1. Physical-Based Attacks

- **Dumpster Diving** refers to the act of searching through physical trash or discarded materials to uncover confidential or sensitive data that can be exploited for malicious intent [5]. Hackers typically look for documents that may contain personal data, proprietary information, or other sensitive materials.
- **Shoulder Surfing** involves an attacker observing a target to gather private information. This technique requires positioning behind the target to discreetly view their screen or keyboard, allowing the attacker to capture passwords or other confidential data without the victim's awareness [6].
- **Tailgating and Piggybacking** are methods of gaining unauthorized access to secure areas by following another person into a restricted location. This can be achieved, by following someone into a restricted location, or taking advantage of their assistance, such as asking them to hold the door while claiming to have forgotten an access badge [2].
- **KeyStroke Injection** is a USB device, often disguised as a thumb drive, that automatically inserts key strokes on any host computer it is plugged into. This attack can be used to create a remote access to the victims machine, or even install malware on it.
- **Keylogger** is a malicious software or USB device that silently records every keystroke on a compromised machine. It records sensitive information entered by users, such as passwords, which can then be accessed by the hacker.
- **Rogue Router** is an unauthorized access point that is connected to a network. The social engineer can create a wifi network with a similar Service

Set Identifier (SSID) from a public free wifi, luring victims into connecting to it, which then can be leveraged to create Man in the middle (MITM) attacks or retrieve sensitive data from the user.

- **Deauthenticator** forces connected devices to disconnect, by disrupting the victim's network connection and tricking users into reconnecting to a rogue access point. They are commonly employed alongside MITM attacks to intercept sensitive information.

5.2. Technical-Based Attacks

- **Phishing** is a fraudulent technique in which attackers deceive individuals into divulging sensitive information or credentials through fake emails or messages that seem to come from trustworthy organizations, such as banks or reputable online services. These attacks usually aim to reach a broad audience to maximize their effectiveness [6]. Phishing has several variants:
 - **Spear Phishing** is a targeted form of phishing which focuses on specific individuals or organizations. These attacks leverage personal details to craft a convincing narrative, which significantly enhances their likelihood of success [7].
 - **Whaling** is a specialized form of spear phishing aimed at high-ranking officials or key decision-makers within an organization [7].
 - **Vishing and Smishing** are forms of phishing which rely on different communication methods. Vishing, uses phone calls to manipulate victims into providing personal information, while smishing delivers phishing messages via SMS which contain harmful links or a requests for sensitive data [7].
 - **Search Engine Phishing** involves strategically placing fraudulent websites at the top of search engine results to deceive users. They may unintentionally enter personal information or download malware from these sites that pose as legitimate services [8].
- **Watering Hole Attack** targets specific groups by compromising websites frequently visited by them. Once these are infected with malware, attackers can subsequently exploit users who visit them [6].
- **Fake Software** attacks consist of creating counterfeit login pages which closely resemble authentic websites. Users unknowingly provide their sensitive information, which gets captured by the attacker, who may then redirect them to the legitimate site, leaving these victims unaware of the breach [2].
- **Pop-Up Windows** trick users into entering their login credentials through misleading alerts about connection problems or malware. These pop-ups

might also present false solutions which activate malware instead of resolving the reported issue [2].

- **DNS Spoofing** involves altering DNS requests to divert user from legitimate websites to fraudulent ones. This tactic typically employs cloned sites aimed at capturing sensitive information [8].

5.3. Social-Based Attacks

- **Impersonation** attacks involve an attacker disguising as someone known to the victim, such as a colleague or authority figure. It exploits the victim's sense of familiarity and trust to share sensitive information or perform actions they otherwise wouldn't. Frequently, it is used as a foundation for other methods, such as those described below.
- **Pretexting** consists of planning a fabricated story to persuade someone into sharing personal details. For example, an attacker might pretend to be an IT staff member requesting credentials to access the organization's systems [2].
- **Quid Pro Quo** operates on the concept of "something for something", where attackers promise attractive offers, such as special deals or giveaways, in exchange for personal data like usernames or email addresses [8].
- **Reverse Social Engineering** involves drawing the victim into making contact with the attacker. For instance, an email may instruct them to reach out to customer support, which in reality leads them to a number controlled by the hacker. This approach makes victims more likely to share personal information because they initiated the contact themselves, reducing suspicion about the legitimacy of the interaction [5].
- **Baiting** takes advantage of curiosity or desire by leaving infected USB drives in public spaces or offering enticing free software for a limited time. When victims interact with these bait items, they may unknowingly install harmful software [8].

6. PREVENTION AND MITIGATION MEASURES

Awareness programs are a vital aspect of an organization's strategy against social engineering, as they reduce the success rate of the attacks. These initiatives are designed to provide employees with the knowledge and skills necessary to identify, prevent, and respond to such threats. They should educate employees about the diverse types of social engineering attacks which they may encounter, and train them to recognize suspicious behaviors, such as unusual requests, unsolicited communications, or unauthorized attempts to access restricted areas. Furthermore, awareness programs should point out best practices in cybersecurity, including the use of strong passwords, proper disposal of documents, and cautious online behaviour, as these are fundamental to

safeguarding organizational assets. To achieve better outcomes, organizations must adopt interactive and engaging training methods that reflect real-world scenarios, such as simulated phishing campaigns and penetration testing. These approaches not only provide valuable insights into employee preparedness but also highlight areas that need improvement in the defense mechanisms and awareness programs [2, 1].

Phishing campaigns replicate attacks by sending malicious emails to employees, which access whether individuals identify them, avoid engaging with them or share sensitive information to the security team. In this campaign, several metrics help the organization evaluate staff practices and the effectiveness of previous training. The **click rate** refers to the percentage of individuals who interact with the email, whether by clicking on a malicious link or downloading an attachment. The number of people who **report and inquire** about emails helps measure how sensitized the staff is to recognizing suspicious threats and knowing how to report them. Ultimately, this enables cybersecurity teams to identify and mitigate threats more quickly. **Reporting even after falling** can also offer key insights, in the case of a real threat. If an employee has been tricked into clicking a link, it is important that they report it immediately to reduce the damage of the attack significantly. **Monitoring the data that is disclosed** helps the cybersecurity team understand what data employees are more susceptible to give, such as personal information or sensitive company information like business plans, financial data, and others. **Tracking statistics over time** helps measure how well the awareness training has improved employee vigilance. It provides insights into which types of attacks are being recognized regularly, which have decreased in success due to training, and which programs might not be yielding positive results [9].

By tracking these metrics, using tools such as GoPhish, the organization can determine if the results from the tests are positive, meaning that individuals are effectively identifying and avoiding manipulation attempts. In such a scenario, organizations can gradually increase the difficulty of these tests, ensuring that teams remain consistently challenged and continue to improve their ability to recognize attacks. On the other hand, high click rate or interaction with phishing emails can pinpoint which departments are more susceptible to attacks, and may require additional training. It also helps identify which types of phishing campaigns are more effective in each department, allowing the creation of targeted training programs to address specific vulnerabilities and improve overall security awareness.

Penetration testing are controlled security assessments which simulate real attack scenarios, to uncover vulnerabilities in technical or physical defenses, policies, and even employees' practices. By mimicking the tactics of a potential hacker, institutions gain valuable

insight to address existing weaknesses before they can be exploited [10]. Hardware tools, such as the Wi-Fi Pineapple, can further enhance these tests by demonstrating how unauthorized devices can infiltrate a system. Organizations can use these tools in controlled environments to evaluate employee responses, applying similar metrics as phishing campaigns.

It is crucial that companies do not stop conducting these tests, given the constantly evolving nature of cybersecurity threats and social engineering techniques. Periodic assessments are essential to reinforce key concepts and skills, by regularly reviewing test results. Institutions can adapt their training programs to address weaker areas identified in each round of testing, which ensures their training and awareness programs remain effective.

To mitigate social engineering threats, organizations should implement technical controls such as phishing detection systems, firewalls, and monitoring software to reduce the likelihood of malicious content reaching employees. Additionally, implementing biometric and Multi-Factor Authentication (MFA) can protect sensitive systems, even if an attacker gains access to user credentials. Finally regularly reviewing and updating security measures is crucial to ensure the organization's defenses remain updated and effective against evolving threats [2, 1].

7. CHALLENGES

Current methods of awareness training typically rely on a **one-size-fits-all** approach, failing to account for variations in experience levels and individual susceptibility. Training must be provided to all staff, from high-level executives to janitors, making implementation challenging, due to the diverse technical backgrounds of employees [11].

Social engineering tactics are continuously evolving as cybercriminals adapt to the preventive measures institutions put in place. As they develop new and more sophisticated techniques, staff become increasingly unfamiliar with these threats, making its recognition more difficult. This issue is further aggravated by the lack of resources dedicated to cybersecurity, which means training programs generally fail to **keep up** with emerging threats. Additionally, organizations must regularly test employee readiness, but the difficulty in allocating staff to conduct training and develop modern programs, combined with the high costs of training, makes it challenging. Individuals often lack the motivation to participate in regular training, leading to a uncaring attitude that undermines the effectiveness of these programs, which ultimately leaves them more vulnerable to attacks and unaware of emerging threats [11].

One challenge which can leave organizations vulnerable to social engineering attacks is the tendency to focus on digital cybersecurity while underestimating the risks

posed by physical social engineering. Often organizations allocate the majority of their security budgets to technological defenses and basic physical security measures, such as surveillance systems, guards, and locks. This imbalance, motivated by limited resources, usually leads to prioritizing the most common attack types and thus neglecting human factor attacks.

The cost associated with physical penetration testing for these tests can be especially high for small institutions with limited budgets or for large organizations with multiple facilities to evaluate. They often rely on external teams, given the complexity of the tests, which further adds to the financial concern. In addition to the cost, physical penetration testing can be disruptive and may cause unintended negative consequences, such as crashing of outdated systems during the testing process. To minimize potential damage, testers should anticipate hazards and take preventive measures, such as shutting down critical operations, which can interfere with ongoing projects and processes [12].

8. CONCLUSIONS

Social engineering remains one of the most significant threats to organizational security, as it targets the human, which is the weakest link in the cybersecurity chain. Despite advancements in technology, attackers continue to exploit psychological vulnerabilities, bypassing even the most sophisticated technical defenses. Effective mitigation requires a approach that balances technological measures, comprehensive staff training, and proactive assessments. Strategies, such as implementing tailored awareness programs, conducting simulated phishing campaigns, and using penetration testing, demonstrate the importance of aligning organizational defenses with real-world attack scenarios. However, challenges such as evolving attack tactics, diverse employee skill levels, and resource constraints complicate these efforts. Organizations must continuously adapt their strategies to address emerging threats, integrating both digital and physical security measures to mitigate risks. Developing affordable tools for physical penetration testing and updating training programs to reflect the latest social engineering trends are critical for maintaining an adaptive and resilient security posture. By fostering a culture of security awareness, leveraging robust technical controls, and regularly evaluating vulnerabilities, organizations can significantly reduce the success rate of social engineering attacks. These integrated efforts enhance overall cybersecurity and provide the agility needed to face a constantly evolving threat landscape.

REFERENCES

- [1] Parthy, P. P. and Rajendran, G. Identification and prevention of social engineering attacks on an enterprise. *2019 International Carnahan Conference on Security Technology (ICCST)*. IEEE.
- [2] Salahdine, F. and Kaabouch, N. Social engineering attacks: A survey. *Future internet*, **11**.
- [3] Mitnick, K. D. and Simon, W. L. *The art of deception: Controlling the human element of security*. John Wiley & Sons.
- [4] Mouton, F., Malan, M. M., Leenen, L., and Venter, H. S. Social engineering attack framework. *2014 Information Security for South Africa*. IEEE.
- [5] Koyun, A. and Al Janabi, E. Social engineering attacks. *Journal of Multidisciplinary Engineering Science and Technology (JMEST)*, **4**, 7533–7538.
- [6] Krombholz, K., Hobel, H., Huber, M., and Weippl, E. Advanced social engineering attacks. *Journal of Information Security and applications*, **22**.
- [7] Leonov, P. Y., Vorobyev, A. V., Ezhova, A. A., Kotelyanets, O. S., Zavalishina, A. K., and Morozov, N. V. The main social engineering techniques aimed at hacking information systems. *2021 Ural symposium on biomedical engineering, radioelectronics and information technology (USBEREIT)*. IEEE.
- [8] Salama, R., Al-Turjman, F., Bhatla, S., and Yadav, S. P. Social engineering attack types and prevention techniques—a survey. *2023 International Conference on Computational Intelligence, Communication Technology and Networking (CICTN)*. IEEE.
- [9] Volkamer, M., Sasse, M. A., and Boehm, F. Analysing simulated phishing campaigns for staff. *Computer Security: ESORICS 2020 International Workshops, DETIPS, DeSECSys, MPS, and SPOSE, Guildford, UK, September 17–18, 2020, Revised Selected Papers 25*. Springer.
- [10] Marusenko, R., Sokolov, V., and Skladannyi, P. Social engineering penetration testing in higher education institutions. *International Conference on Computer Science, Engineering and Education Applications*. Springer.
- [11] Aldawood, H. and Skinner, G. Reviewing cyber security social engineering training and awareness programs—pitfalls and ongoing issues. *Future internet*, **11**.
- [12] Teichmann, F. M. and Boticiu, S. R. An overview of the benefits, challenges, and legal aspects of penetration testing and red teaming. *International Cybersecurity Law Review*, **4**.